GTFO-VER IT!!! You Already Accept This Risk

A wake-up call for CISOs who are scared of uploading a policy doc to Claude but perfectly fine emailing it to four auditors they've never met.

ROCK LAMBROS

DIRECTOR OF AI STANDARDS & GOVERNANCE, ZENITY

FOUNDER, ROCKCYBER

OWASP AGENTIC SECURITY INITIATIVE CORE TEAM

Let Me Guess What You're Afraid Of

You block team access to paid AI tools because:

What if the model trains on our data?

Irrational fear. The probability is near zero (0.000001%). Major enterprise vendors banned training on your data back in 2023. You're losing sleep over a threat that died two years ago. The real risk is your team using personal accounts on unmanaged hardware. Focus on that instead.

What if it leaks to another tenant?

Irrational fear. Also solved. Tenant isolation is standard architecture. These systems get patched just like the other SaaS products you already trust. Your team's shared email inboxes are a far bigger exposure. Stop using AI as a scapegoat.

What if a vendor breach exposes our docs?

Irrational fear. This risk exists for your email, SharePoint, Jira, and every consultant you've hired. You accepted these risks long ago; you just didn't label them "AI risk."

You're fighting a ghost from two years ago while your team uses personal ChatGPT on the side. **Congrats.**

Here Is The Number You Actually Need

Annual probability of external leak from a well-governed enterprise LLM:

0.1–1%

Enterprise LLM Leak Risk

Fault tree model. Real breach patterns. Verizon DBIR 2025.

Same

As Email, SharePoint & Drive

That is not a special AI number. It is the same range as every tool you already trust.

#1

Dominant Leak Path

Compromised credentials and human error. Not the model. Not the vendor.

> The dominant leak path is compromised credentials and human error. Not the model. Not the vendor. **Karen in finance clicking a phishing link. Same as always.**

Where That Number Comes From

Here are the fault tree formulas used to derive the risk estimate.

1

The core leak probability formula

$$P(\text{leak}) = P(\text{path exists}) \times P(\text{control failure}) \times P(\text{access}) \times P(\text{disclosure})$$

2

Aggregated across all threat paths

$$P(\text{total}) = 1 - (1 - p_1)(1 - p_2)(1 - p_3)...(1 - p_n)$$

3

User-driven risk at scale

$$P(\text{user risk}) = 1 - (1 - p_{\text{user}})^N$$

4

At 50 users with a 0.1% individual leak rate

$$P = 1 - (1 - 0.001)^{50} \approx 4.9\%$$

No empirical enterprise LLM leak dataset exists; these are fault tree estimates anchored to Verizon DBIR 2025 baselines. This remains the most rigorous available model—and it confirms you are likely focused on the wrong risks.

The Reality You've Been Avoiding

Your Current Workflow: Email

200

External shares per year

0.1%

Error rate per share

~18%

Annual leak probability

A Governed Enterprise LLM (50 Users)

SSO Enforced

MFA on. No consumer tools.

~5%

Annual leak probability

3–4×

Safer than your email habit

And yet here you are, blocking the tool while forwarding audit evidence to a shared Gmail inbox.

Training Data Exposure Is A Dead Fear

Your 2022 threat model is obsolete; every major enterprise vendor has contractually prohibited training on customer data for years.

Vendor	Trains on data?	Retention control
OpenAI Enterprise	No	Configurable
Microsoft Copilot	No	M365 governed
Google Gemini Enterprise	No	Workspace DLP
Claude Enterprise/API	No	Zero data retention available

What You're About to Watch

Stuff I do every day

01

Start with a bad prompt

Type the worst version of "build me a CISO assistant" and watch what a vague prompt produces.

02

Build something that actually works

Tear it apart and rebuild it with a scoped role and constrained behavior to create the CISO Co-Pilot system prompt.

03

Create the project live

CISO Co-Pilot goes live with knowledge loaded, and you'll see exactly what goes in.

04

Run a real scenario

Triage a production AI feature shipped without security review or data classification containing customer PII.

What You're Actually Choosing Between

This is not safe vs. unsafe. This is **visible risk vs. invisible risk.**

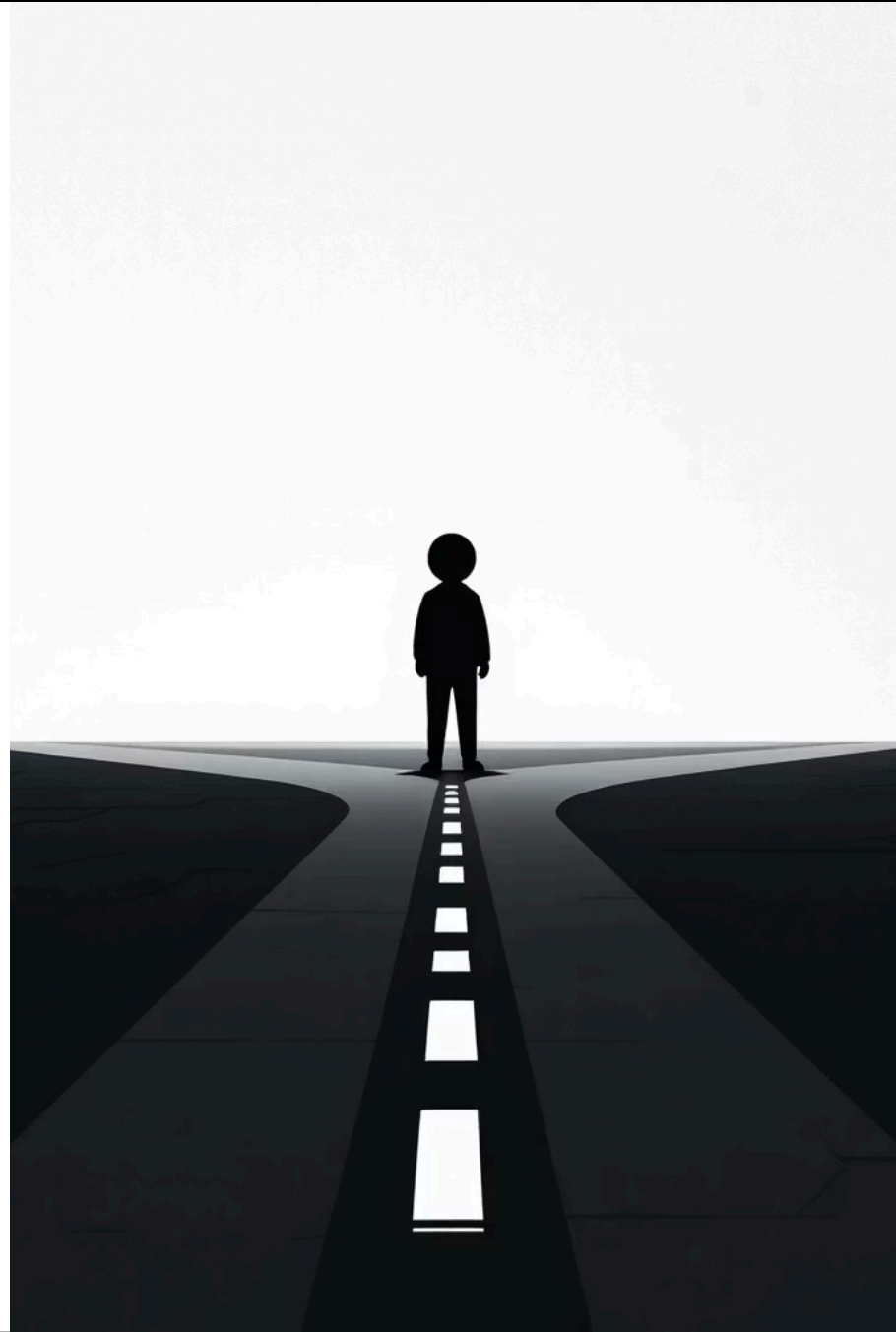
Option A: Controlled Enterprise AI

- Auditable and governed
- SSO enforced, MFA required
- Every prompt is logged
- Retention configurable to zero
- You have a full audit trail

Option B: Block It

- Team uses personal accounts anyway
- Zero visibility into usage
- No audit trail whatsoever
- No controls of any kind
- Full shadow AI on hardware you don't own

> **Blocking enterprise AI does not reduce risk. It moves risk somewhere you cannot see, cannot audit, and cannot stop. You're not protecting the data. You're losing visibility of it.**



What Is Actually Safe To Upload Right Now

Upload Freely

- Policies and standards
- Audit narratives
- Internal frameworks
- Board presentations
- Control documentation

Upload With Basic Controls

Redact first. Scope access.

- Architecture diagrams
- IR playbooks
- Raw incident logs (unless they contain creds)
- Semi-sensitive audit evidence

Never in a Chat UI

Use API with zero retention only.

- Credentials and secrets
- Regulated PII
- Anything your lawyers would panic about

Required baseline: SSO, phishing-resistant MFA, connectors off by default, short retention, DLP enforced. None of this is exotic. You already have most of it.

CISO [un]prompted GitHub Drops

Scan to grab the repos

ciso-claude-toolkit

CISO Co-Pilot system prompts, scoped roles, and constrained behavior templates for Claude.

github.com/rocklambros/ciso-claude-toolkit

any2md

Convert anything to clean Markdown. Built for security practitioners who live in docs.

github.com/rocklambros/any2md

This Presentation

The slides you're looking at right now.

bit.ly/gtfoverit